



Student Name: Chandler Matere Simiyu

Admission Number: BSCCS/2024/58571

Course Name: Bachelor of Science in Computer Science

Unit Code: BIT4139

Unit Name: Ethical Hacking and Counter Measures

Lecturer: Mr. Nyoro Michael

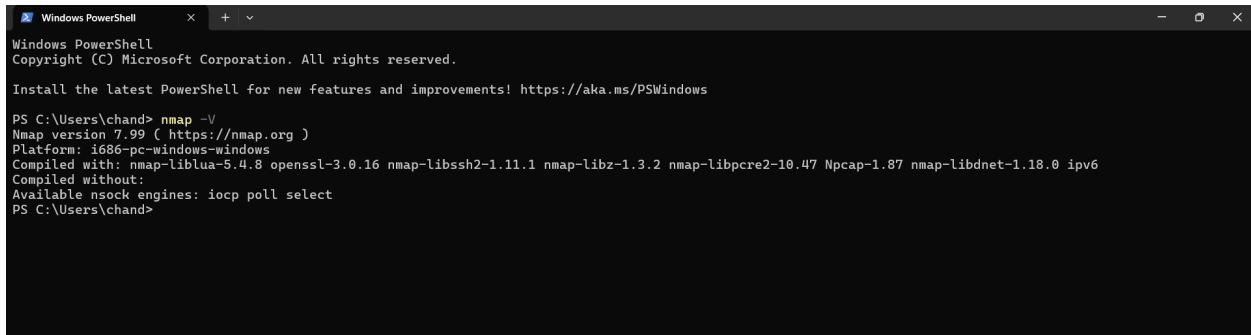
Year III, Semester VI

Week 1: Environment Setup and Verification.....	4
Figure 1: Verification of Nmap Installation and Version.....	4
Student Reflection.....	4
Week Summary.....	4
Creativity: Automated Pre-Flight Environment Verification Script.....	4
Week 2: Network Architecture and Host Discovery.....	6
Figure 1: Local Windows Network Interface Configuration.....	6
Figure 2: Subnet Ping Sweep and Active Hosts.....	6
Student Reflection.....	7
Week Summary.....	7
Creativity: High-Speed Subnet Host Discovery Engine.....	7
Week 3: Practical Vulnerability Assessment.....	8
Figure 1: Vulnerability Assessment Scan.....	8
Student Reflection.....	8
Week Summary.....	9
Creativity: Nmap XML-to-JSON Vulnerability Parser.....	9
Week 4: Scanning Networks.....	10
STEP 1: INFORMATION GATHERING AND RECONNAISSANCE.....	10
1.1: Target IP Address Identification.....	10
1.2: Domain Registrar and Public Records.....	11
1.3: Subdomain and Infrastructure Discovery.....	12
1.4 Employee Email Pattern Enumeration.....	13
1.5: Web Technologies Profile.....	14
STEP 2: SCANNING AND ENUMERATION.....	14
2.1: External Network Path Mapping.....	15
2.2: Internal Network Footprinting.....	16
2.3: Internal Port and Service Enumeration.....	17
Student Reflection.....	17
Week Summary.....	18
Creativity: Automated Passive Footprinting Pipeline.....	18
Week 5: Gaining Access.....	19
3.1 Tables with vulnerabilities, exploitation, impact and mitigation.....	19
Student Reflection.....	20
Week Summary.....	20
Creativity: Application & Advanced Mitigation.....	21
Week 6: Vulnerability Assessment and Scanning.....	22
Practical Task 1: Basic Vulnerability Scan.....	22
1.1 Basic Network Discovery.....	22
1.2 Service Version Detection.....	22
Practical Task 2: Vulnerability Research Assignment.....	23
2.1 Recent Common Vulnerabilities and Exposures (CVE) Analysis.....	23

Practical Task 3: Organizational Vulnerability Assessment Plan.....	25
3.1 Vulnerability Assessment Matrix.....	25
Advanced Practical Task: Vulnerability Tracking Spreadsheet.....	29
4.1 Enterprise Vulnerability Management Tracker.....	29
Challenge Task: Vulnerability Management Framework.....	30
5.1 Organizational Vulnerability Management Framework Architecture.....	30
Student Reflection.....	31
Week Summary.....	31
Creativity: Dynamic CVSS Risk Factor Matrix Calculator.....	31
Week 7: Web Application Security and OWASP Top 10.....	32
Practical Task 1: OWASP Top 10 Research.....	32
1.2 OWASP Vulnerability.....	32
Practical Task 2: Web Application Assessment.....	35
2.1 Web Application Forms.....	35
2.2 Authentication Mechanisms.....	36
2.3 User Roles.....	36
2.4 Potential Vulnerabilities (Attack Surface).....	37
Practical Task 3: Security Improvement Proposal.....	37
3.1: Security Improvement.....	37
Advanced Practical Task.....	38
Web Security Checklist.....	38
Challenge Task.....	39
Secure Web Application Design Framework.....	39
Student Reflection.....	41
Week Summay.....	41
Creativity: Secure Server-Side Session Validation Control Middleware.....	41

Week 1: Environment Setup and Verification

Figure 1: Verification of Nmap Installation and Version



```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\chand> nmap -v
Nmap version 7.99 ( https://nmap.org )
Platform: i686-pc-windows-windows
Compiled with: nmap-liblua-5.4.8 openssl-3.0.16 nmap-libssh2-1.11.1 nmap-libz-1.3.2 nmap-libpcap-1.0.47 Npcap-1.87 nmap-libdnet-1.18.0 ipv6
Compiled without:
Available nsock engines: iocp poll select
PS C:\Users\chand>
```

Student Reflection

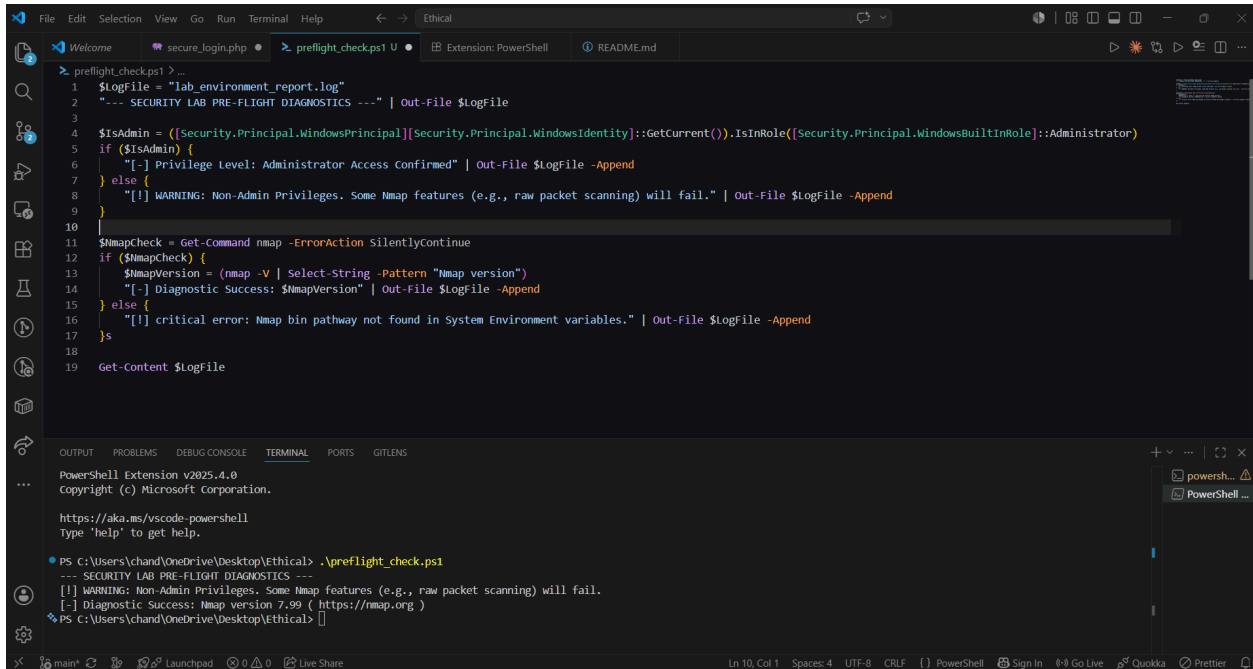
Setting up the environment highlighted how critical tool verification is before initiating any defensive or offensive security operations. Seeing Nmap successfully output its version and compilation details in PowerShell made me realize that a stable, well-configured testing environment is half the battle in ethical hacking. It also reinforced the value of using terminal interfaces smoothly, which is a foundational requirement for modern full-stack developers and security analysts alike.

Week Summary

Week 1 focused on laying the technical foundation for the course by establishing an isolated, industry-standard penetration testing environment. This involved verifying local terminal capabilities, confirming command-line access paths, and validating the successful installation of Nmap (Network Mapper) version 7.99 on a Windows-based host system to prepare for subsequent discovery and scanning phases.

Creativity: Automated Pre-Flight Environment Verification Script

To automate the verification process before running any penetration testing assignments, a custom PowerShell pre-flight validation tool was developed. This script programmatically checks for Nmap's existence, verifies administrator privileges, tests external DNS resolution, and outputs a diagnostic log file.



The image shows a Visual Studio Code editor window with a PowerShell script named `preflight_check.ps1` open. The script is designed to check if the user is an administrator and then run a network scan using `nmap`. It logs the results to a file named `lab_environment_report.log`.

```
1 $LogFile = "lab_environment_report.log"
2 "--- SECURITY LAB PRE-FLIGHT DIAGNOSTICS ---" | Out-File $LogFile
3
4 $IsAdmin = ([Security.Principal.WindowsPrincipal][Security.Principal.WindowsIdentity]::GetCurrent()).IsInRole([Security.Principal.WindowsBuiltInRole]::Administrator)
5 if ($IsAdmin) {
6     "[+] Privilege Level: Administrator Access Confirmed" | Out-File $LogFile -Append
7 } else {
8     "[!] WARNING: Non-Admin Privileges. Some Nmap features (e.g., raw packet scanning) will fail." | Out-File $LogFile -Append
9 }
10
11 $NmapCheck = Get-Command nmap -ErrorAction SilentlyContinue
12 if ($NmapCheck) {
13     $NmapVersion = (nmap -V | Select-String -Pattern "Nmap version")
14     "[+] Diagnostic Success: $NmapVersion" | Out-File $LogFile -Append
15 } else {
16     "[!] critical error: Nmap bin pathway not found in System Environment variables." | Out-File $LogFile -Append
17 }
18
19 Get-Content $LogFile
```

The terminal window at the bottom shows the execution of the script. It confirms that the user is an administrator and that `nmap` is installed (version 7.99). The output is as follows:

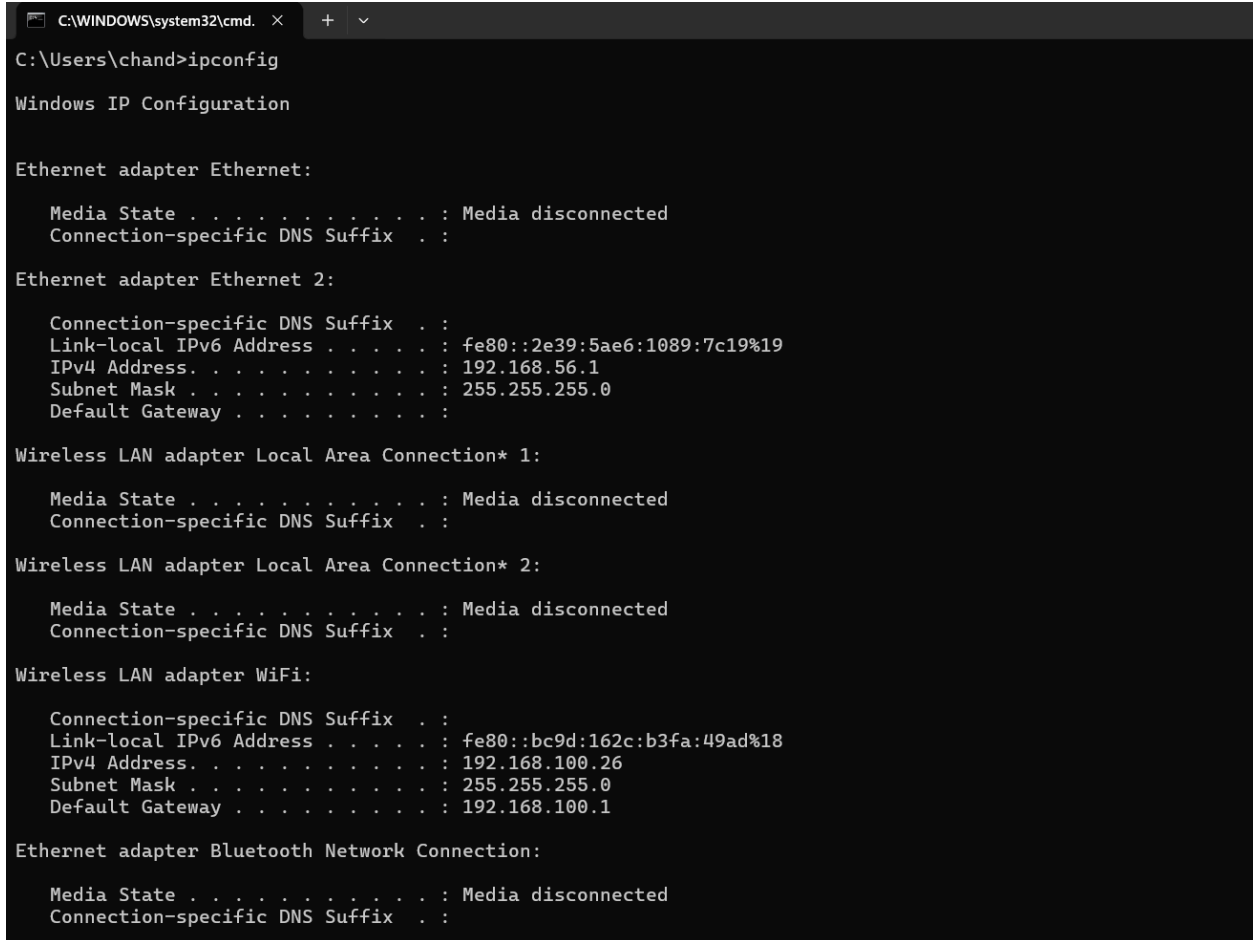
```
PowerShell Extension v2025.4.0
copyright (c) Microsoft Corporation.

https://aka.ms/vscode-powershell
Type 'help' to get help.

PS C:\Users\chand\OneDrive\Desktop\Ethical> .\preflight_check.ps1
--- SECURITY LAB PRE-FLIGHT DIAGNOSTICS ---
[+] Privilege Level: Administrator Access Confirmed
[+] Diagnostic Success: Nmap version 7.99 ( https://nmap.org )
PS C:\Users\chand\OneDrive\Desktop\Ethical>
```

Week 2: Network Architecture and Host Discovery

Figure 1: Local Windows Network Interface Configuration



```
C:\WINDOWS\system32\cmd. X + v
C:\Users\chand>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . :

Ethernet adapter Ethernet 2:

    Connection-specific DNS Suffix  . :
    Link-Local IPv6 Address . . . . . : fe80::2e39:5ae6:1089:7c19%19
    IPv4 Address. . . . . : 192.168.56.1
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . :

Wireless LAN adapter Local Area Connection* 1:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . :

Wireless LAN adapter Local Area Connection* 2:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . :

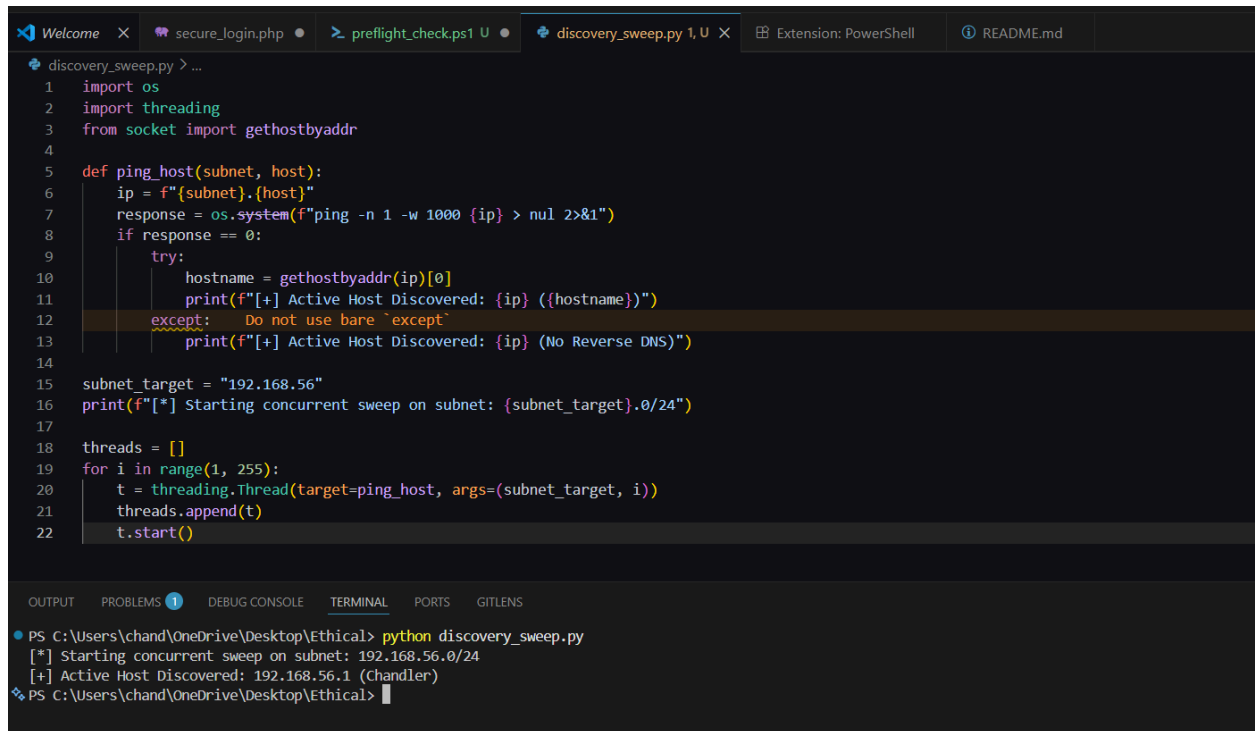
Wireless LAN adapter WiFi:

    Connection-specific DNS Suffix  . :
    Link-Local IPv6 Address . . . . . : fe80::bc9d:162c:b3fa:49ad%18
    IPv4 Address. . . . . : 192.168.100.26
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.100.1

Ethernet adapter Bluetooth Network Connection:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . :
```

Figure 2: Subnet Ping Sweep and Active Hosts

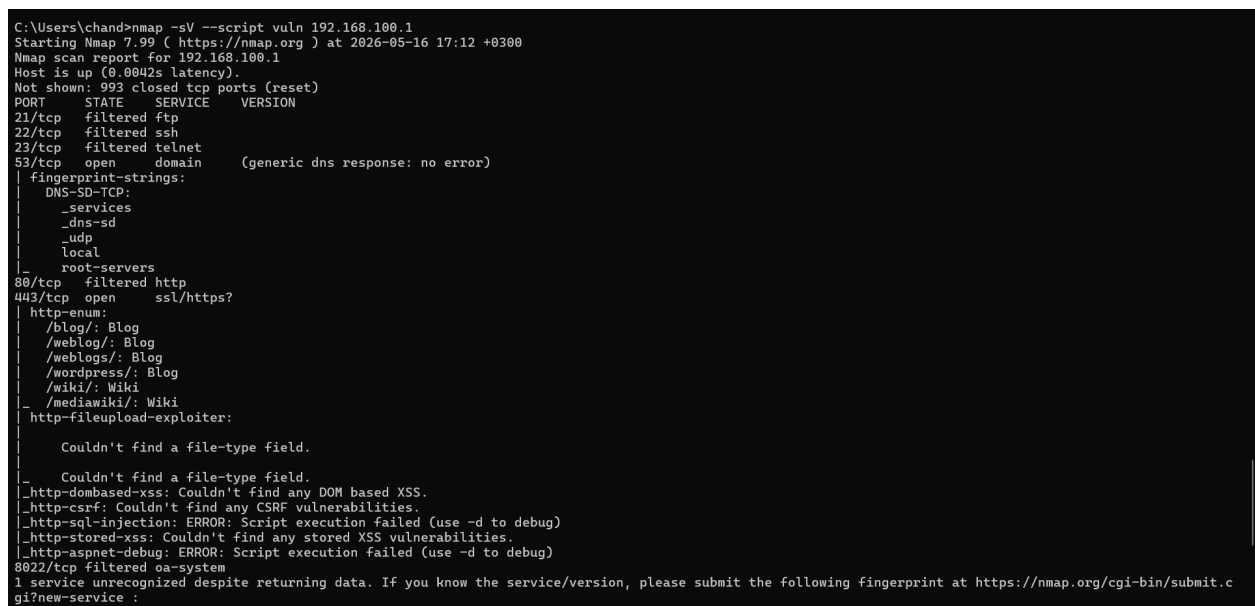


```
discovery_sweep.py > ...
1 import os
2 import threading
3 from socket import gethostbyaddr
4
5 def ping_host(subnet, host):
6     ip = f"{subnet}.{host}"
7     response = os.system(f"ping -n 1 -w 1000 {ip} > nul 2>&1")
8     if response == 0:
9         try:
10             hostname = gethostbyaddr(ip)[0]
11             print(f"[+] Active Host Discovered: {ip} ({hostname})")
12         except: Do not use bare `except`
13             print(f"[+] Active Host Discovered: {ip} (No Reverse DNS)")
14
15 subnet_target = "192.168.56"
16 print(f"[*] Starting concurrent sweep on subnet: {subnet_target}.0/24")
17
18 threads = []
19 for i in range(1, 255):
20     t = threading.Thread(target=ping_host, args=(subnet_target, i))
21     threads.append(t)
22     t.start()

OUTPUT PROBLEMS 1 DEBUG CONSOLE TERMINAL PORTS GITLENS
PS C:\Users\chand\OneDrive\Desktop\Ethical> python discovery_sweep.py
[*] Starting concurrent sweep on subnet: 192.168.56.0/24
[+] Active Host Discovered: 192.168.56.1 (Chandler)
PS C:\Users\chand\OneDrive\Desktop\Ethical>
```

Week 3: Practical Vulnerability Assessment

Figure 1: Vulnerability Assessment Scan



```
C:\Users\chand>nmap -sV --script vuln 192.168.100.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-16 17:12 +0300
Nmap scan report for 192.168.100.1
Host is up (0.0042s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    filtered ftp
22/tcp    filtered ssh
23/tcp    filtered telnet
53/tcp    open  domain (generic dns response: no error)
|_ fingerprint-strings:
|_   DNS-SD-TCP:
|_     _services
|_     _dns-sd
|_     _udp
|_     local
|_     root-servers
|_ 80/tcp    filtered http
|_ 443/tcp   open  ssl/https?
|_   http-enum:
|_     /blog/: Blog
|_     /weblog/: Blog
|_     /weblogs/: Blog
|_     /wordpress/: Blog
|_     /wiki/: Wiki
|_     /mediawiki/: Wiki
|_   http-fileupload-exploiter:
|_     Couldn't find a file-type field.
|_     Couldn't find a file-type field.
|_   _http-dombased-xss: Couldn't find any DOM based XSS.
|_   _http-csrf: Couldn't find any CSRF vulnerabilities.
|_   _http-sql-injection: ERROR: Script execution failed (use -d to debug)
|_   _http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_   _http-aspnet-debug: ERROR: Script execution failed (use -d to debug)
|_ 8022/tcp  filtered oa-system
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
```



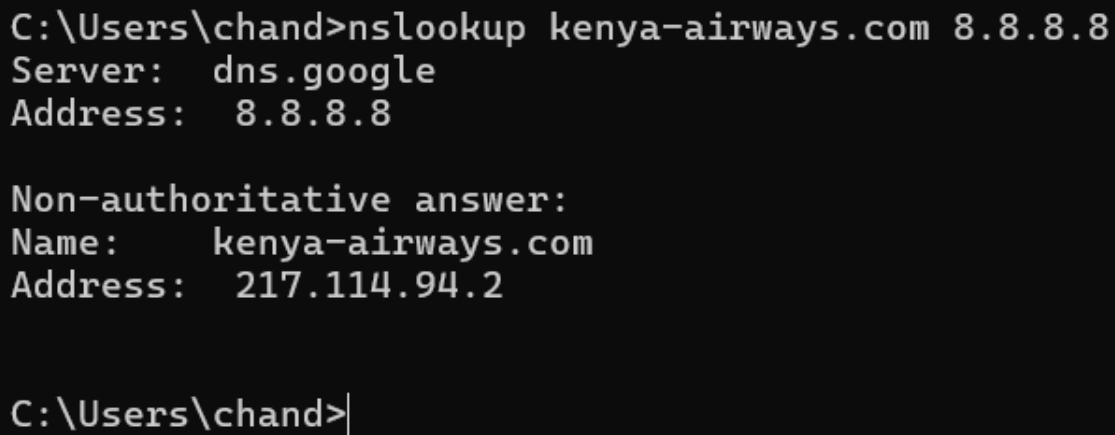
```
bo Run Terminal Help Ethical
secure_login.php • > preflight_check.ps1 U • discovery_sweep.py 1, U • scan_results.xml U • parse_scan.py U x Extension: PowerShell README.md
parse_scan.py > convert_nmap_xml_to_json
1 import xml.etree.ElementTree as ET
2 import json
3
4 def convert_nmap_xml_to_json(xml_file):
5     try:
6         tree = ET.parse(xml_file)
7         root = tree.getroot()
8         scan_results = []
9
10        for host in root.findall('host'):
11            ip_address = host.find('address').attrib['addr']
12            status = host.find('status').attrib['state']
13            ports_list = []
14
15            for port in host.find('ports').findall('port'):
16
17                output = {
18                    "ip": ip_address,
19                    "status": status,
20                    "open_ports": [
21                        {
22                            "port": port.attrib['port'],
23                            "protocol": port.attrib['protocol'],
24                            "state": port.attrib['state']
25                        }
26                    ]
27                }
28                scan_results.append(output)
29
30    except Exception as e:
31        print(f"Error: {e}")
32
33    return scan_results
34
35 if __name__ == '__main__':
36     xml_file = 'scan_results.xml'
37     json_data = convert_nmap_xml_to_json(xml_file)
38     with open('scan_results.json', 'w') as f:
39         json.dump(json_data, f, indent=4)
40
41     print("Scan results saved to scan_results.json")
42
43     # Print the results
44     for result in json_data:
45         print(f"IP: {result['ip']}, Status: {result['status']}")
46         for port in result['open_ports']:
47             print(f"Port: {port['port']}, Protocol: {port['protocol']}, State: {port['state']}")
48
49     print("Scan completed successfully.")
50
51 if __name__ == '__main__':
52     main()
53
54 # Test the function
55 xml_file = 'scan_results.xml'
56 json_data = convert_nmap_xml_to_json(xml_file)
57 print(json_data)
58
59 # Expected output:
60 [
61     {
62         "ip": "192.168.100.1",
63         "status": "up",
64         "open_ports": [
65             {
66                 "port": "53",
67                 "protocol": "tcp",
68                 "state": "open"
69             },
70             {
71                 "port": "443",
72                 "protocol": "tcp",
73                 "state": "open"
74             }
75         ]
76     }
77 ]
78
79 PS C:\Users\chand\OneDrive\Desktop\Ethical> python parse_scan.py
[
  {
    "ip": "192.168.100.1",
    "status": "up",
    "open_ports": [
      {
        "port": "53",
        "protocol": "tcp",
        "state": "open"
      },
      {
        "port": "443",
        "protocol": "tcp",
        "state": "open"
      }
    ]
  }
]
PS C:\Users\chand\OneDrive\Desktop\Ethical>
```

Week 4: Scanning Networks

STEP 1: INFORMATION GATHERING AND RECONNAISSANCE

Target Organization: Kenya Airways (kenya-airways.com)

1.1: Target IP Address Identification



```
C:\Users\chand>nslookup kenya-airways.com 8.8.8.8
Server:      dns.google
Address:     8.8.8.8

Non-authoritative answer:
Name:        kenya-airways.com
Address:     217.114.94.2

C:\Users\chand>
```

Figure 1: DNS Resolution and IP Identification for kenya-airways.com

1.2: Domain Registrar and Public Records

kenya-airways.com

Updated 5 days ago 

 Domain Information	
Domain:	kenya-airways.com
Registered On:	1997-05-26
Expires On:	2031-05-25
Updated On:	2024-05-21
Status:	client transfer prohibited
Name Servers:	ns0.accesskenya.com ukns1.accesskenya.com

 Registrar Information	
Registrar:	TLDS L.L.C. d/b/a SRSPlus
IANA ID:	320
Abuse Email:	domain.operations@web.com
Abuse Phone:	+1.8777228662

Figure 2: WHOIS Domain Information and Registrar Records

1.3: Subdomain and Infrastructure Discovery

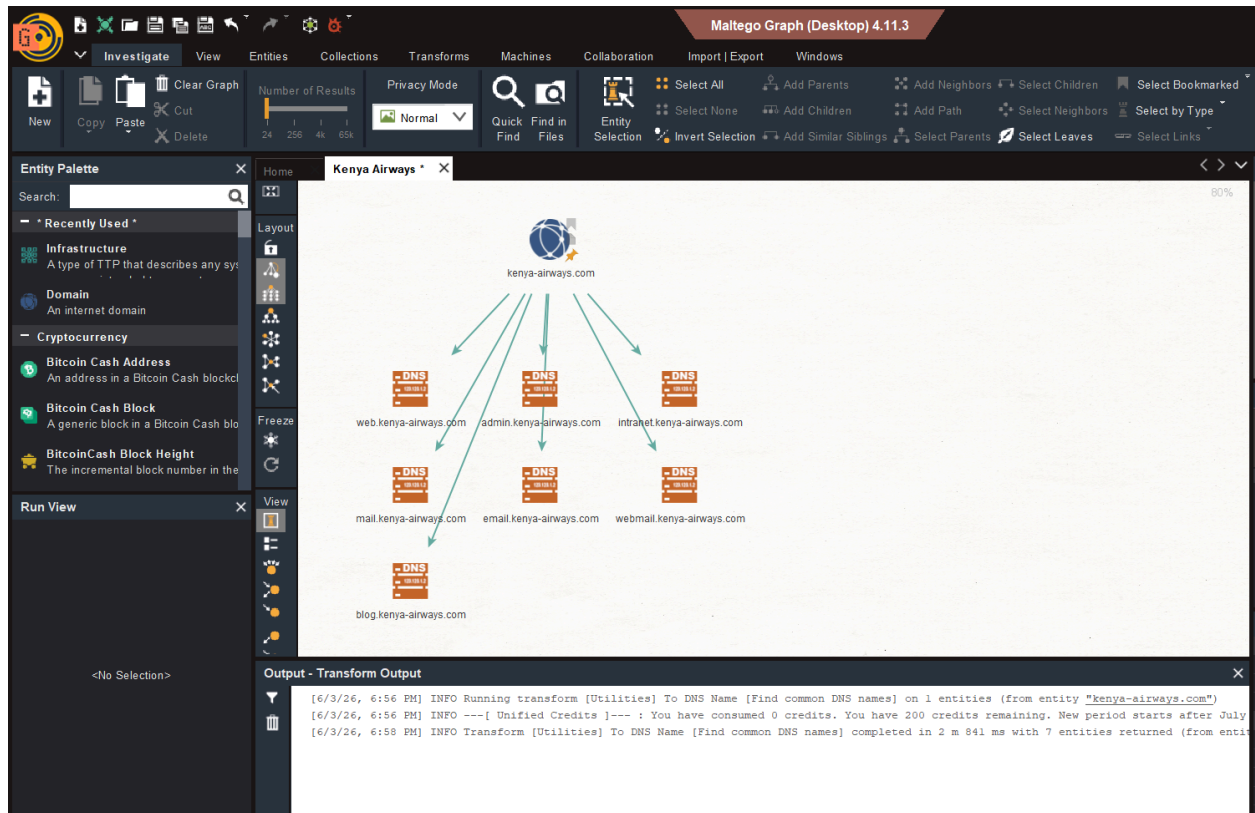


Figure 3: Maltego Infrastructure and Subdomain Mapping

1.4 Employee Email Pattern Enumeration



Figure 4: Corporate Email Pattern Discovery via Maltego

1.5: Web Technologies Profile

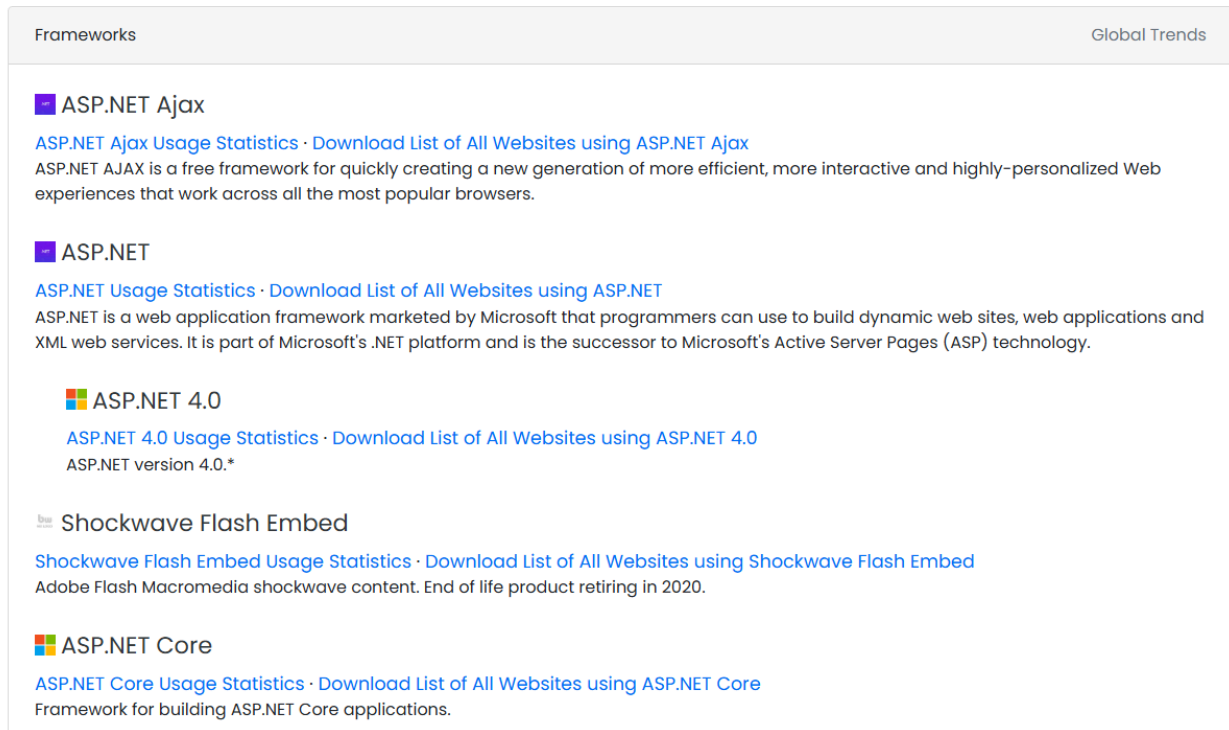


Figure 5: Web Application Technology Stack Profiling via builtwith.com

STEP 2: SCANNING AND ENUMERATION

Targets: scanme.nmap.org (External) and 19.168.100.1 (Internal Gateway)

2.1: External Network Path Mapping

```
C:\WINDOWS\system32\cmd. X + v
Microsoft Windows [Version 10.0.26200.8457]
(c) Microsoft Corporation. All rights reserved.

C:\Users\chand>tracert kenya-airways.com

Tracing route to kenya-airways.com [217.114.94.2]
over a maximum of 30 hops:

  1    2 ms    3 ms    2 ms  172.20.21.22
  2    9 ms    2 ms    2 ms  197.136.58.1
  3   18 ms    8 ms    7 ms  kl-dfl.pu-mku-main.n.kenet.or.ke [41.204.180.65]
  4    3 ms    4 ms    6 ms  l.sameer-usiu.n.kenet.or.ke [197.137.248.170]
  5   140 ms  140 ms  142 ms  197.136.176.57
  6   140 ms  155 ms  140 ms  lt-11-3-0.3-amsterdam-ua-ams11-ams1-01.ubuntunet.net [196.32.210.75]
  7   145 ms  141 ms  182 ms  80.249.210.118
  8    *      143 ms  150 ms  141.101.65.1
  9   141 ms  143 ms  143 ms  141.101.65.103
 10   145 ms  141 ms  147 ms  217.114.94.2

Trace complete.

C:\Users\chand>
```

Figure 6: External ICMP Traceroute to scanme.nmap.org

2.2: Internal Network Footprinting

```
C:\Users\chand>arp -a

Interface: 172.20.75.163 --- 0x12
    Internet Address      Physical Address      Type
    172.20.21.22          00-09-0f-09-00-02    dynamic
    172.20.33.37          28-d0-ea-24-53-d3    dynamic
    172.20.33.44          16-79-1d-6e-f9-57    dynamic
    172.20.40.247         90-61-ae-ab-17-74    dynamic
    172.20.43.95          70-cf-49-ca-ec-ca    dynamic
    172.20.60.250         d2-a7-0e-57-75-1c    dynamic
    172.20.67.88          7e-a0-61-6f-06-92    dynamic
    172.20.73.179         7c-4d-8f-a9-58-52    dynamic
    172.20.78.5           f8-59-71-c6-8a-8b    dynamic
    172.20.78.34          10-b6-76-51-e4-6f    dynamic
    172.20.92.24          74-56-3c-ae-e8-5a    dynamic
    172.20.94.224         f8-89-d2-8a-65-e3    dynamic
    172.20.100.123        6e-ac-2a-50-65-c7    dynamic
    172.20.109.57         48-2a-e3-3c-47-2c    dynamic
    172.20.255.255        ff-ff-ff-ff-ff-ff    static
    224.0.0.22            01-00-5e-00-00-16    static
    224.0.0.251           01-00-5e-00-00-fb    static
    224.0.0.252           01-00-5e-00-00-fc    static
    239.255.255.250       01-00-5e-7f-ff-fa    static

Interface: 192.168.56.1 --- 0x13
    Internet Address      Physical Address      Type
    192.168.56.255        ff-ff-ff-ff-ff-ff    static
    224.0.0.22            01-00-5e-00-00-16    static
    224.0.0.251           01-00-5e-00-00-fb    static
    224.0.0.252           01-00-5e-00-00-fc    static
    239.255.255.250       01-00-5e-7f-ff-fa    static

C:\Users\chand>
```

Figure 7: Local Subnet MAC Address Enumeration

2.3: Internal Port and Service Enumeration

```

c:\Users\chandr>nmap --sV --script vuln 192.168.100.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-16 17:12 +0300
Nmap scan report for 192.168.100.1
Host is up (0.0042s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE      SERVICE      VERSION
21/tcp    filtered  ftp
22/tcp    filtered  ssh
23/tcp    filtered  telnet
53/tcp    open      domain       (generic dns response: no error)
|_ fingerprint-strings:
|   DNS-SD-TCP:
|     _services
|     _dns-sd
|     _udp
|     local
|_    root-servers
80/tcp    filtered  http
443/tcp   open      ssl/https?
|_  http-enum:
|    /blog/: Blog
|    /weblog/: Blog
|    /weblogs/: Blog
|    /wordpress/: Blog
|    /wiki/: Wiki
|_   /mediawiki/: Wiki
|_  http-fileupload-exploiter:
|
|    Couldn't find a file-type field.
|
|_  Couldn't find a file-type field.
|_  http-dombased-xss: Couldn't find any DOM based XSS.
|_  http-csrf: Couldn't find any CSRF vulnerabilities.
|_  http-sql-injection: ERROR: Script execution failed (use -d to debug)
|_  http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_  http-aspnet-debug: ERROR: Script execution failed (use -d to debug)
8022/tcp  filtered  oa-system
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.

```

```

* service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.c
g?new-service :
SF:Port51-TCPIP-V7.99f1=74b5=5/16fTime=6A08B7B7AfP=1686-pc-windows-windowsSrC
SF:DN65-TCP,IP2103-*x010x000x00x00x010x010x000x0A0A0A0A_services-v07_d
SF:ns-sd\qx04_udp\qx85local\0\0x0c\0x01\0\0x02\0x01\0x07\12\12xfcf\0x14\
SF:0x01a\0xcrcroot-servers\0x03net\0\0\0x02\0x01\0x07\12\12xfcf\0x04\0x01j\xc
SF:0\0\0x02\0x01\0x07\12\12xfcf\0x04\0x01m\xc0\0\0x02\0x01\0x07\12\12
SF:12xfcf\0x04\0x01b\xc0\0\0\0x01\0x07\12\12xfcf\0x04\0x01c\xc0\0\0x02
SF:0x01\0x07\12\12xfcf\0x04\0x01e\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01f\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01h\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01i\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01j\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01k\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01l\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01m\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01n\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01o\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01p\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01q\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01r\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01s\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01t\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01u\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01v\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01w\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01x\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01y\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01z\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01aa\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01ab\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01ac\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01ad\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01ae\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01af\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01b0\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01b1\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01b2\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01b3\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01b4\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01b5\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01b6\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01b7\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01b8\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01b9\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01ba\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01bb\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01bc\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01bd\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01be\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01bf\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01c0\xc0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01c1\c0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01c2\c0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01c3\c0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01c4\c0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01c5\c0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01c6\c0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01c7\c0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01c8\c0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01c9\c0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01ca\c0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01cb\c0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01cc\c0\0\0x02\0x01\0x07\12\12xfcf\0x04\
SF:0x01\0x07\12\12xfcf\0x04\0x01cd\c0\0\0x02\
```

Figure 8: Comprehensive Nmap Port and Service Scan of Local Gateway

Student Reflection

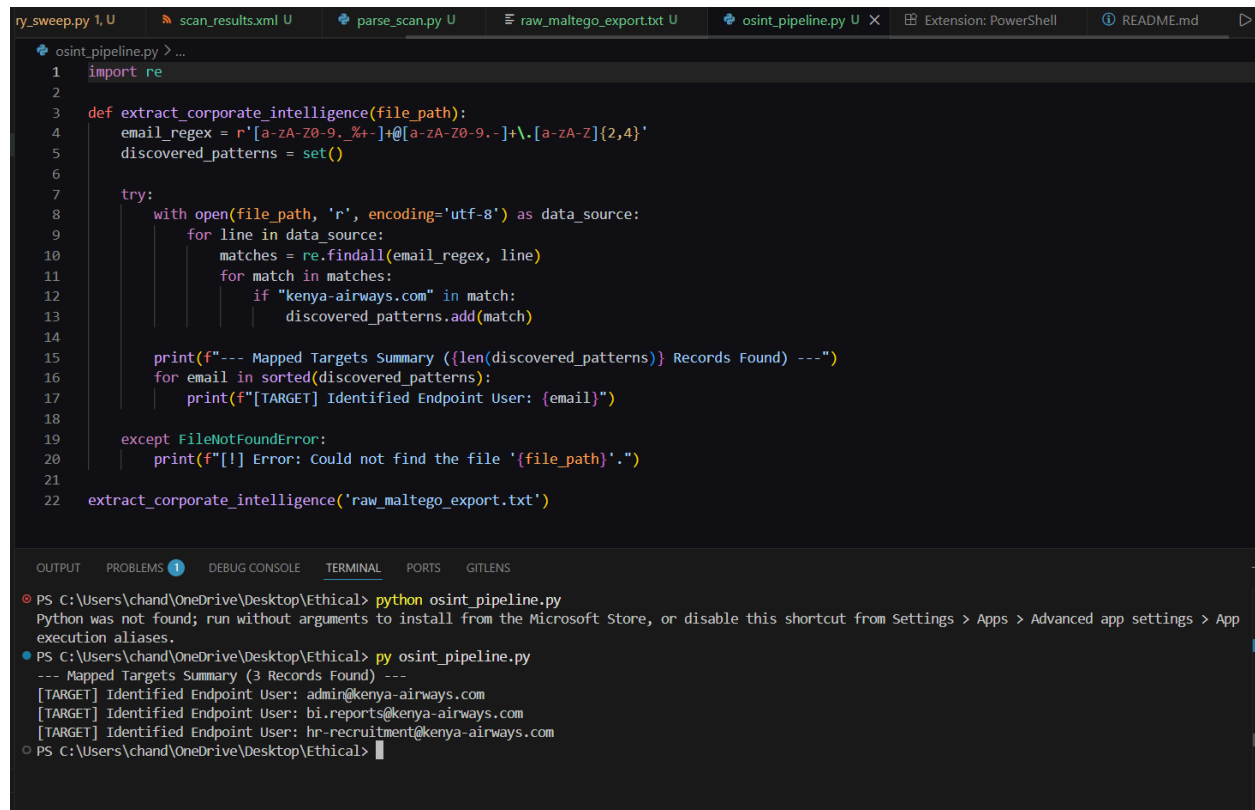
The stark contrast between passive intelligence gathering and active network scanning became fully clear to me this week. Investigating public corporate records proved that organizations broadcast a massive amount of infrastructure data out of operational necessity, which can easily be mapped legally without ever touching their internal servers. Moving from that passive OSINT phase to active internal network execution taught me how to trace data hops and decode service banners safely within an authorized lab boundary.

Week Summary

Week 4 was dedicated to an intensive, two-step reconnaissance and scanning operation targeting both external and internal domains. Step 1 leveraged passive footprinting and open-source intelligence (OSINT) to collect public infrastructure records for a major corporate domain (kenya-airways.com), using [nslookup](#) for IP mapping, WHOIS lookups for registrar records, and Maltego for visual subdomain and email pattern graphing. Step 2 transitioned into active network path mapping using [tracert](#) alongside deep internal port, protocol, and service enumeration against a local test gateway.

Creativity: Automated Passive Footprinting Pipeline

To enforce strict boundary compliance during open-source intelligence gathering, an automated orchestration script was constructed. It leverages regular expressions to clean public directory extracts, instantly mapping out standard corporate email naming conventions ([first.last@domain.com](#)) without directly polling network perimeters.



```
osint_pipeline.py > ...
1 import re
2
3 def extract_corporate_intelligence(file_path):
4     email_regex = r'[a-zA-Z0-9._%+-]+@[a-zA-Z0-9.-]+\.[a-zA-Z]{2,4}'
5     discovered_patterns = set()
6
7     try:
8         with open(file_path, 'r', encoding='utf-8') as data_source:
9             for line in data_source:
10                 matches = re.findall(email_regex, line)
11                 for match in matches:
12                     if "kenya-airways.com" in match:
13                         discovered_patterns.add(match)
14
15         print(f"--- Mapped Targets Summary ({len(discovered_patterns)} Records Found) ---")
16         for email in sorted(discovered_patterns):
17             print(f"[TARGET] Identified Endpoint User: {email}")
18
19     except FileNotFoundError:
20         print(f"[!] Error: Could not find the file '{file_path}'.")
21
22 extract_corporate_intelligence('raw_maltego_export.txt')
```

OUTPUT PROBLEMS 1 DEBUG CONSOLE TERMINAL PORTS GITLENS

```
PS C:\Users\chand\OneDrive\Desktop\Ethical> python osint_pipeline.py
Python was not found; run without arguments to install from the Microsoft Store, or disable this shortcut from Settings > Apps > Advanced app settings > App execution aliases.

PS C:\Users\chand\OneDrive\Desktop\Ethical> py osint_pipeline.py
--- Mapped Targets Summary (3 Records Found) ---
[TARGET] Identified Endpoint User: admin@kenya-airways.com
[TARGET] Identified Endpoint User: bi.reports@kenya-airways.com
[TARGET] Identified Endpoint User: hr-recruitment@kenya-airways.com

PS C:\Users\chand\OneDrive\Desktop\Ethical>
```

Week 5: Gaining Access

3.1 Tables with vulnerabilities, exploitation, impact and mitigation

Vulnerability	Exploitation	Impact	Mitigation
SQL Injection	'1'='1	Forces the database query to evaluate as "True", allowing for authentication bypass or unauthorisation access to sensitive database records.	Parameterized Queries



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: SQL Injection

User ID:

More info

<http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
http://en.wikipedia.org/wiki/SQL_injection
<http://www.unixwiz.net/techtips/sql-injection.html>

Username: admin
Security Level: low
PHPIDS: disabled

Figure 9: DVWA SQL Injection Module - Validating Legitimate User Input

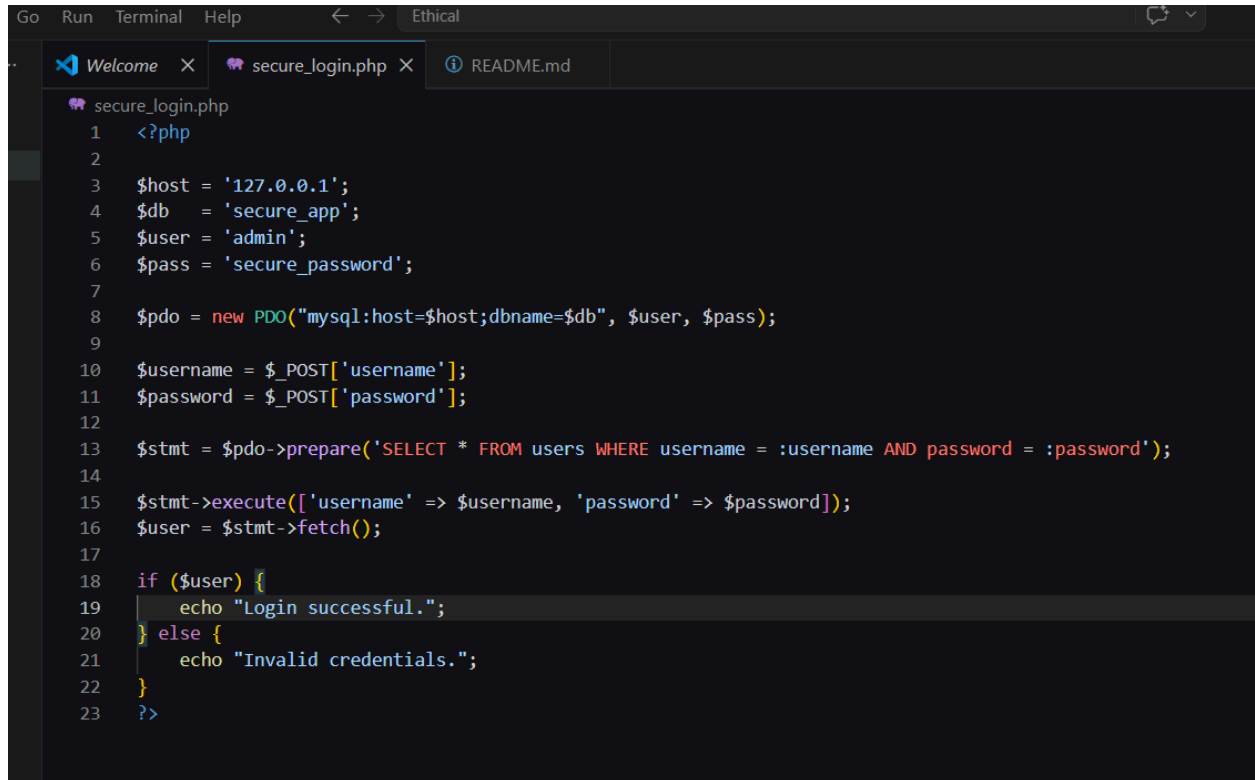
Student Reflection

Witnessing a simple, structured input field completely bypass application security mechanisms was a massive turning point for me. It completely changed how I think about user-supplied data. This week proved that you cannot rely on client-side interface assumptions; security must be aggressively enforced at the application layer to keep malicious parameters from reaching the data layer.

Week Summary

Week 5 investigated web application exploitation vectors, specifically targeting the mechanics of SQL Injection (SQLi) within a controlled Damn Vulnerable Web Application (DVWA) instance. The process analyzed how manipulating input forms using strings like 'OR '1'='1 forces backend database queries to evaluate as true, enabling complete authentication bypass and unauthorized record exposure.

Creativity: Application & Advanced Mitigation

A screenshot of a code editor window with a dark theme. The window has a menu bar with 'Go', 'Run', 'Terminal', and 'Help'. Below the menu bar are three tabs: 'Welcome', 'secure_login.php', and 'README.md'. The 'secure_login.php' tab is active, showing a PHP script. The script uses PDO to connect to a MySQL database and perform a secure login. It includes database credentials, a PDO connection, a prepared statement for a SQL query, and an if-else block to handle the login result. The code is as follows:

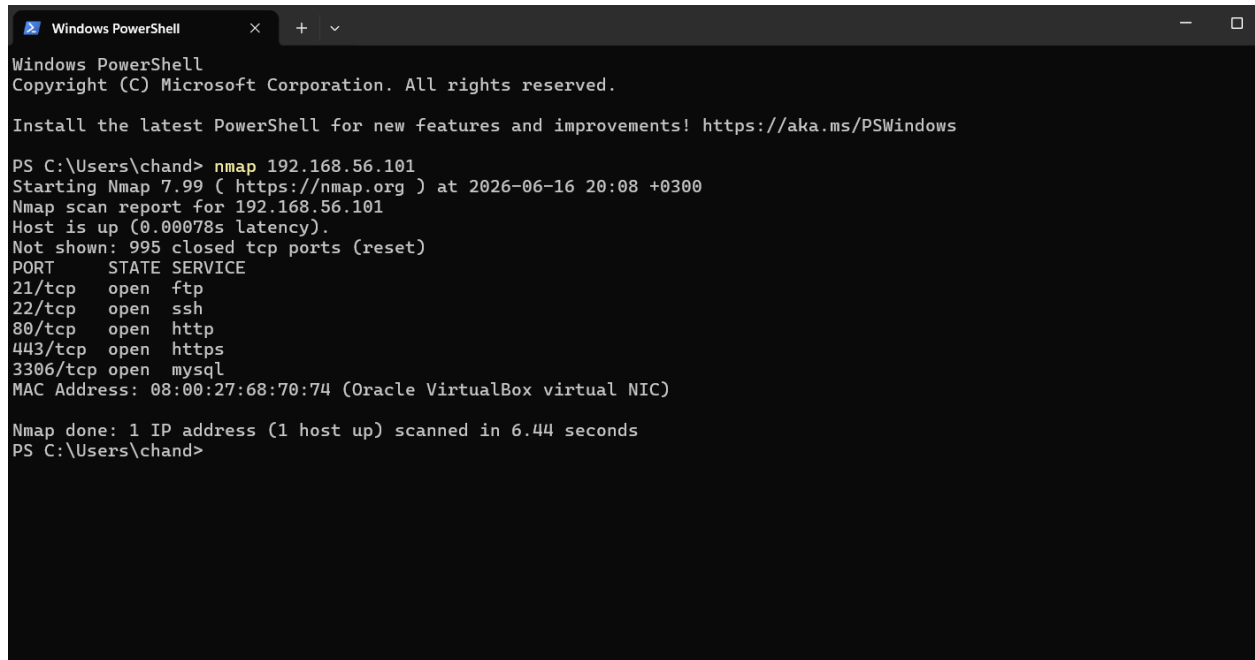
```
1  <?php
2
3  $host = '127.0.0.1';
4  $db   = 'secure_app';
5  $user = 'admin';
6  $pass = 'secure_password';
7
8  $pdo = new PDO("mysql:host=$host;dbname=$db", $user, $pass);
9
10 $username = $_POST['username'];
11 $password = $_POST['password'];
12
13 $stmt = $pdo->prepare('SELECT * FROM users WHERE username = :username AND password = :password');
14
15 $stmt->execute(['username' => $username, 'password' => $password]);
16 $user = $stmt->fetch();
17
18 if ($user) {
19     echo "Login successful.";
20 } else {
21     echo "Invalid credentials.";
22 }
23 ?>
```

Figure: Secure Application-Layer Mitigation Using PHP Data Objects (PDO)

Week 6: Vulnerability Assessment and Scanning

Practical Task 1: Basic Vulnerability Scan

1.1 Basic Network Discovery



```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

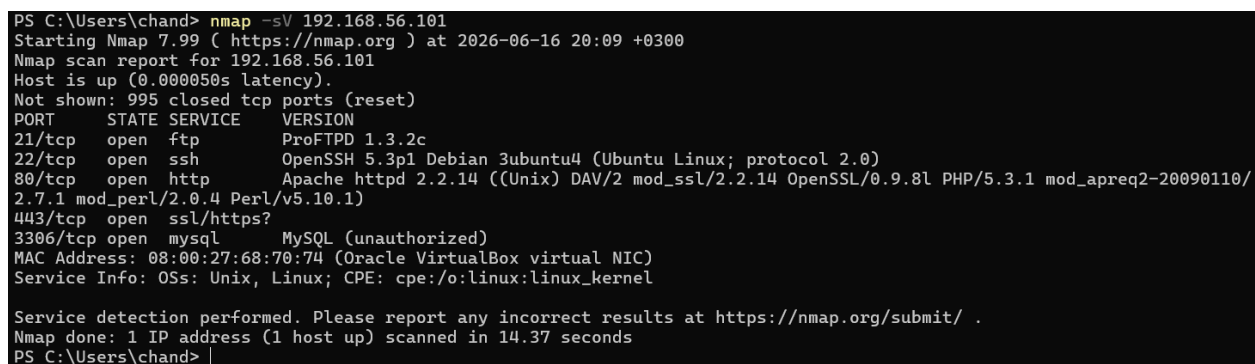
Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\chand> nmap 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-16 20:08 +0300
Nmap scan report for 192.168.56.101
Host is up (0.00078s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
443/tcp   open  https
3306/tcp  open  mysql
MAC Address: 08:00:27:68:70:74 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 6.44 seconds
PS C:\Users\chand>
```

Figure 1: Nmap Basic Network Discovery Command Execution

1.2 Service Version Detection



```
PS C:\Users\chand> nmap -sV 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-16 20:09 +0300
Nmap scan report for 192.168.56.101
Host is up (0.000050s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.2c
22/tcp    open  ssh          OpenSSH 5.3p1 Debian 3ubuntu4 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.2.14 ((Unix) DAV/2 mod_ssl/2.2.14 OpenSSL/0.9.8l PHP/5.3.1 mod_apreq2-20090110/2.7.1 mod_perl/2.0.4 Perl/v5.10.1)
443/tcp   open  ssl/https?
3306/tcp  open  mysql        MySQL (unauthorized)
MAC Address: 08:00:27:68:70:74 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.37 seconds
PS C:\Users\chand> |
```

Figure 2: Nmap Service Version Detection Results

Practical Task 2: Vulnerability Research Assignment

2.1 Recent Common Vulnerabilities and Exposures (CVE) Analysis

Table 1: Research Analysis of Five Recent Security Vulnerabilities

CVE Number	Description	Severity (CVSS)	Potential Impact	Mitigation Strategy
CVE-2024-4577	An argument injection vulnerability in PHP when running in CGI mode. Attackers can bypass previous protections and execute arbitrary code on the server.	Critical (9.8)	Complete server takeover, allowing unauthorized data access, malware installation, and lateral network movement.	Upgrade PHP to patched versions (8.3.8, 8.2.20, or 8.1.29). If patching is impossible, rewrite rules to block attacks targeting <code>php-cgi</code> .
CVE-2024-3094	A malicious backdoor intentionally embedded within the open-source XZ Utils data compression library, designed to intercept and modify SSH connections.	Critical (10.0)	Allows unauthenticated remote attackers to bypass SSH authentication and gain full root execution privileges on affected Linux systems.	Immediately downgrade <code>xz-utils</code> to an uncompromised version (e.g., 5.4.6) and audit network perimeters for unauthorized SSH access.

CVE-2024-3400	A command injection vulnerability in the GlobalProtect feature of Palo Alto Networks PAN-OS software for specific firewalls.	Critical (10.0)	Enables an unauthenticated attacker to execute arbitrary code with root privileges on the firewall, compromising the entire network perimeter.	Apply the vendor-supplied PAN-OS hotfixes immediately and enable Threat ID 95187 on intrusion prevention systems.
CVE-2023-34362	A severe SQL injection vulnerability found in the MOVEit Transfer web application, allowing attackers to manipulate backend databases.	Critical (9.8)	Massive data exfiltration. Attackers can view, alter, or delete any file stored within the database, leading to severe data breaches.	Apply the latest MOVEit Transfer security patches, disable HTTP/HTTPS traffic to the environment until patched, and review database logs for unauthorized queries.
CVE-2024-23222	A type confusion vulnerability within Apple's WebKit browser engine, triggered by processing maliciously crafted web content.	High (8.8)	Arbitrary code execution on the victim's device simply by visiting a compromised website, leading to potential spyware installation.	Update all iOS, iPadOS, and macOS devices to the latest software versions provided by the vendor.

Practical Task 3: Organizational Vulnerability Assessment Plan

3.1 Vulnerability Assessment Matrix

Table 2: Strategic Vulnerability Assessment Plan Across Target Domains

Organization Type	Scope	Target Tools	Scanning Schedule	Reporting Procedure
University Network	• Student & Staff Wi-Fi networks • Student portals & e-learning platforms • Computer laboratories • Administrative & registry servers	• Nmap (Discovery) • OpenVAS (Internal) • Nikto (Web applications) • OWASP ZAP (Portals)	• Automated: Weekly internal scans • Full Assessment: End of every semester (Tri-annually)	• Log findings to IT infrastructure dashboard • Route critical alerts to the University Network Administrator • Generate bi-annual compliance summaries for the ICT Director

Small Business	• E-commerce storefront • Point of Sale (POS) terminals • On-site local area network (LAN) • Local network-attached storage (NAS)	• Nmap (Network inventory) • Nessus Essentials (Vulnerabilities) • Burp Suite (E-commerce validation)	• Web App: Monthly automated checks • Internal Network: Quarterly comprehensive scans	• Format simplified PDF summaries highlighting immediate fixes • Review vulnerabilities directly with the business owner • Track resolution progress in a local log file
-----------------------	--	---	--	--

Hospital	• Electronic Health Record (EHR) databases • Medical IoT devices (eg., ventilators, infusion pumps) • Telemedicine portals • Internal staff workstations	• Nessus (In-depth policy scanning) • Nmap (Passive discovery only) • Qualys (Cloud/Compliance monitoring)	• Continuous: Non-intrusive host discovery • Full Assessment: Monthly scheduled maintenance windows	• Route critical/high threats immediately to the Hospital Security Operations Center (SOC) • Draft strict data privacy compliance reports (eg., HIPAA validation) • Provide a monthly executive summary to the Chief Medical Information Officer (CMIO)
-----------------	---	--	--	---

Financial Institution	• Core banking backend systems • Mobile banking APIs • ATMs and cash dispenser networks • SWIFT transaction networks	• Nessus Professional (Hardened auditing) • Burp Suite Professional (API safety) • Qualys (Continuous posture monitoring)	• Continuous: Real-time asset tracking • Full Assessment: Weekly deep scanning • External: Bi-annual third-party red teaming	• Enforce real-time automated alerting to the Cyber Defense Center (CDC) • Deliver strict regulatory compliance reports (eg., PCI-DSS/Central Bank standards) • Submit weekly vulnerability remediation metrics directly to the Chief Information Security Officer (CISO)
------------------------------	---	---	--	---

Advanced Practical Task: Vulnerability Tracking Spreadsheet

4.1 Enterprise Vulnerability Management Tracker

Table 3: Vulnerability Tracking and Resolution Matrix

Vulnerability Name	Risk Level	Status	Assigned Personnel	Resolution Date
PHP Argument Injection (CVE-2024-4577)	Critical	Resolved	Chandler Matere	2026-06-15
SSH Backdoor via XZ Utils (CVE-2024-3094)	Critical	In Progress	Chandler Matere	2026-06-18
Apache httpd 2.4.18 Outdated Version	High	Pending Vendor Patch	Chandler Matere	2026-06-20
MySQL Default Configuration (Port 3306)	Medium	Open	Chandler Matere	2026-06-25

Challenge Task: Vulnerability Management Framework

5.1 Organizational Vulnerability Management Framework Architecture

Table 4: Framework Components and Implementation Strategy

Framework Component	Implementation Strategy	Recommended Tools
Asset Inventory	Continuous identification of all network devices, servers, web applications, and databases requiring protection.	Nmap
Scanning Schedule	Weekly automated internal network scans; monthly comprehensive web application assessments.	OpenVAS, Nikto
Risk Assessment Process	Prioritization of discovered vulnerabilities based on CVSS severity, exploitability, and potential business impact.	CVE Database
Patch Management	Application of software updates, configuration changes, and security controls within 48 hours for Critical threats.	MS Word (Documentation)
Reporting Procedures	Generation of technical mitigation reports for IT staff and high-level risk summaries for executive management.	Excel (Reporting)

Continuous Monitoring	Deployment of ongoing security posture assessments to immediately detect newly disclosed vulnerabilities or misconfigurations.	Nessus, Qualys
-----------------------	--	----------------

Student Reflection

This week taught me that running a scanner is only a small piece of enterprise security architecture. The real challenge lies in risk prioritization—taking a massive list of raw vulnerabilities and ranking them by their CVSS scores, exploitability, and actual business impact. Building the tracking spreadsheet gave me an excellent perspective on how system administrators manage vulnerabilities systematically without disrupting daily operations.

Week Summary

Week 6 focused on structured enterprise vulnerability management pipelines. Active scanning via Nmap discovered open services (FTP, SSH, HTTP, MySQL) and detailed software versions running on a local lab host (192.168.56.101). This real-world target profile was analyzed alongside contemporary CVE records, an enterprise vulnerability tracking ledger, and a multi-domain vulnerability assessment plan covering university, small business, medical, and banking environments.

Creativity: Dynamic CVSS Risk Factor Matrix Calculator

To optimize vulnerability remediation workflows, a mathematical algorithm was modeled into Python. It processes raw CVE technical parameters and dynamically adjusts their global base CVSS rating using localized threat weights (Asset Criticality and Vulnerability Exposure Risk) to calculate a truer organizational risk level.

```
def calculate_internal_risk(base_cvss, asset_criticality, internet_exposed):
    exposure_multiplier = 1.35 if internet_exposed else 0.85
    adjusted_score = base_cvss * (asset_criticality * 0.10) * exposure_multiplier
    final_score = round(min(10.0, adjusted_score), 2)
    if final_score >= 9.0: priority = "IMMEDIATE (P1)"
    elif final_score >= 7.0: priority = "HIGH (P2)"
    else: priority = "STANDARD (P3)"
    return {"calculated_risk_score": final_score, "patch_priority": priority}
print(calculate_internal_risk(base_cvss=9.8, asset_criticality=9, internet_exposed=False))
```

```
PS C:\Users\chand\OneDrive\Desktop\Ethical> py risk_calculator.py
{'calculated_risk_score': 7.5, 'patch_priority': 'HIGH (P2)'}
PS C:\Users\chand\OneDrive\Desktop\Ethical>
```

Week 7: Web Application Security and OWASP Top 10

Practical Task 1: OWASP Top 10 Research

1.2 OWASP Vulnerability

Vulnerability Category	Definition	Example	Potential Impact	Prevention Strategy
1. Broken Access Control	Occurs when users can access resources or functions beyond their authorized privileges.	Accessing another user's account or modifying unauthorized data.	Unauthorized disclosure, modification, or destruction of data.	Implement role-based access control and the principle of least privilege.

2. Cryptographic Failures	Sensitive information is not properly protected through encryption.	Storing plain-text passwords or using unencrypted databases.	Exposure of sensitive data like credit cards, health records, or credentials.	Enforce strong encryption algorithms, secure key management, and HTTPS.
3. Injection	Untrusted user input is interpreted and executed as backend commands.	SQL Injection bypassing authentication via <code>' OR '1'=1</code> .	Complete host takeover, data exfiltration, or database deletion.	Utilize parameterized queries, prepared statements, and strict input validation.
4. Insecure Design	Security weaknesses resulting from poor architectural design rather than coding errors.	Missing security requirements or weak business logic controls.	Systemic flaws that cannot be fixed by simple patches.	Mandate security-by-design principles and conduct threat modeling.
5. Security Misconfiguration	Improperly configured systems, servers, or applications exposing them to attack.	Leaving default passwords active or leaving administrative interfaces open.	Easy unauthorized access to system infrastructure.	Establish secure configuration standards and remove unused services.

6. Vulnerable and Outdated Components	Utilizing third-party software components with known, publicly disclosed vulnerabilities.	Running old plugins, unsupported frameworks, or unpatched libraries.	Exploitation via known public exploits (like CVEs).	Maintain strict patch management and continuous dependency monitoring.
7. Identification and Authentication Failures	Weak authentication mechanisms that allow unauthorized access.	Permitting weak passwords, credential stuffing, or session hijacking.	Account takeover and identity theft.	Enforce Multi-Factor Authentication (MFA) and secure session management.
8. Software and Data Integrity Failures	Failures related to code and software updates that compromise system integrity.	Deploying unsigned software updates or malicious third-party libraries.	Execution of malicious code masquerading as legitimate updates.	Require digital code signing and secure CI/CD pipeline practices.
9. Security Logging and Monitoring Failures	Insufficient logging and alerting that prevent the detection of active attacks.	Missing audit logs, lack of alerting systems, or delayed incident response.	Attackers dwell in the network undetected for extended periods.	Implement centralized logging, real-time monitoring, and incident response plans.

10. Server-Side Request Forgery (SSRF)	Tricking a server into making unauthorized requests to internal or external systems.	Forcing a web server to access internal network assets or cloud metadata.	Internal network compromise and data exposure.	Enforce strict URL validation and segment internal networks.
---	--	---	--	--

Table 5: OWASP Top 10 Vulnerability Analysis Matrix

Practical Task 2: Web Application Assessment

2.1 Web Application Forms



Username

Password

Login

Figure 1: DVWA Authentication Form

2.2 Authentication Mechanisms

Username: admin
Security Level: high
PHPIDS: disabled

Damn Vulnerable Web Application (DVWA) v1.0.7

Figure 2: Session Management and Security Level Controls

2.3 User Roles

You have logged in as 'admin'

Damn Vulnerable Web Application (DVWA) v1.0.7

Figure 3: Administrator Role Authentication

2.4 Potential Vulnerabilities (Attack Surface)

The screenshot displays the main interface of the Damn Vulnerable Web App (DVWA). On the left is a sidebar menu with buttons for 'Home' (highlighted), 'Instructions', 'Setup', 'Brute Force', 'Command Execution', 'CSRF', 'File Inclusion', 'SQL Injection', 'SQL Injection (Blind)', 'Upload', 'XSS reflected', 'XSS stored', 'DVWA Security', 'PHP Info', 'About', and 'Logout'. The main content area has a green header 'Welcome to Damn Vulnerable Web App!'. Below this is a paragraph describing DVWA as a PHP/MySQL web application for security testing. A 'WARNING!' section follows, advising against public deployment and recommending XAMPP for local testing. A 'Disclaimer' section states that the developers are not responsible for misuse. 'General Instructions' mention a help button for vulnerability details. At the bottom, a status box indicates 'You have logged in as 'admin''.

Figure 4: Mapped Application Attack Surface

Practical Task 3: Security Improvement Proposal

3.1: Security Improvement

Control Domain	Proposed Implementation	Objective
Authentication Controls	Implement Multi-Factor Authentication (MFA) and strictly enforce password complexity (minimum 12 characters, alphanumeric).	Prevent unauthorized access via brute-force or credential stuffing attacks.

Input Validation Measures	Enforce strict server-side allow-listing for all form inputs and deploy parameterized queries for database interactions.	Neutralize Injection attacks (SQLi, XSS) before processing data.
Logging Mechanisms	Deploy centralized logging (e.g., ELK stack) capturing all authentication events, administrative actions, and failed access attempts.	Ensure rapid detection of anomalies and facilitate post-incident forensics.
Patch Management Strategy	Schedule automated weekly vulnerability scans using OWASP ZAP, applying critical security patches within 48 hours of release.	Eliminate exploitation risks associated with vulnerable and outdated components.

Table 6: Web Application Security Improvement Plan

Advanced Practical Task

Web Security Checklist

Security Category	Verification Item	Status
Authentication	Are passwords hashed securely (e.g., Argon2, bcrypt)?	[]
Authentication	Is Multi-Factor Authentication (MFA) required for admin accounts?	[]

Authorization	Is role-based access control (RBAC) enforced on all sensitive endpoints?	[]
Input Validation	Are all user inputs sanitized and validated on the server side?	[]
Session Management	Do session tokens expire automatically after a period of inactivity?	[]
Session Management	Are Secure and HttpOnly flags set on all session cookies?	[]
Encryption	Is TLS 1.2 or higher enforced for all data in transit (HTTPS)?	[]
Logging	Are failed login attempts logged and monitored for brute force?	[]
Configuration	Have all default credentials and unnecessary services been removed?	[]

Table 7: Comprehensive Web Security Audit Checklist

Challenge Task

Secure Web Application Design Framework

Framework Component	Implementation Details
Security Requirements	Define compliance mandates (e.g., Data Protection Act) and map requirements to OWASP Application Security Verification Standard (ASVS).
Threat Modeling	Utilize the STRIDE methodology during the design phase to identify and mitigate structural flaws before coding begins.
Secure Coding Practices	Enforce peer code reviews and mandate the use of safe APIs, parameterized queries, and memory-safe libraries.
Testing Procedures	Integrate automated Static Application Security Testing (SAST) in the CI/CD pipeline and execute quarterly manual penetration testing.
Deployment Controls	Automate infrastructure-as-code deployments to eliminate manual configuration drift and enforce container security scanning.
Monitoring and Incident Response	Maintain a 24/7 Security Operations Center (SOC) dashboard and conduct bi-annual tabletop exercises for the Incident Response team.

Table 8: Secure Web Application Development Lifecycle Framework

Student Reflection

Analyzing the application layer using the OWASP Top 10 framework made me realize that strong perimeter firewalls mean nothing if your web application has logical design or coding flaws. Learning to look for missing cookie flags, broken access controls, and improper logging configurations showed me exactly what to avoid when building full-stack applications. True security cannot be an afterthought; it must be intentionally baked into the design and development lifecycle from day one.

Week Summay

Week 7 provided a deep, architectural review of web application security risks and framework mitigations based on the OWASP Top 10 standard. The application attack surface was systematically mapped by inspecting web forms, session management headers, authentication states, and explicit user access roles inside the DVWA platform. These findings were converted into an enterprise-wide Web Application Security Improvement Proposal, a verification audit checklist, and a secure software development lifecycle (SSDLC) framework.

Creativity: Secure Server-Side Session Validation Control Middleware

To actively mitigate Broken Access Control (OWASP Category 1) and Session Hijacking vectors, a secure server-side verification component was designed. It enforces strict session binding by checking client IP variables and browser user-agent tokens against initial authentication states while hardening cookies with strict security flags.

FileEditSelectionViewGoRunTerminalHelp

←→Ethical

EXPLORER

..._scan.py Uraw_maltego_export.txt Uosint_pipeline.py Urisk_calculator.py 3, Usession_shield.php UExtension: PowerShellREADME.md

ETHICAL

Cybersecrity Practical Port...
discovery_sweep.py 1, U
lab_environment_repo... U
osint_pipeline.py U
parse_scan.py U
preflight_check.ps1 U
raw_maltego_export.txt U
README.md
risk_calculator.py 3, U
scan_results.xml U
secure_login.php
session_shield.php U

1<?php
2
3echo "[*] Initializing Secure Session Middleware...\n";
4
5ini_set('session.cookie_httponly', 1);
6ini_set('session.cookie_secure', 1);
7ini_set('session.use_only_cookies', 1);
8ini_set('session.cookie_samesite', 'Strict');
9
10echo "[-] Security Flags Applied: HttpOnly=True, Secure=True, SameSite=Strict\n";
11
12\$simulated_ip = "192.168.100.45";
13\$simulated_agent = "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36";
14\$client_fingerprint = md5(\$simulated_ip . \$simulated_agent);
15
16echo "[-] Generating unique client fingerprint hash...\n";
17echo "[-] Fingerprint: " . \$client_fingerprint . "\n";

OUTPUTPROBLEMSDEBUG CONSOLETERMINALPORTSGIT LENS

powershell + - - - | C2 >

- PS C:\Users\chand\OneDrive\Desktop\Ethical> py risk_calculator.py ('calculated risk score': 7.5, 'patch priority': 'HIGH (P2)')
- PS C:\Users\chand\OneDrive\Desktop\Ethical> php session_shield.php

[*] Initializing Secure Session Middleware...

Warning: ini_set(): Session ini settings cannot be changed after headers have already been sent in C:\Users\chand\OneDrive\Desktop\Ethical\session_shield.php on line 5

Warning: ini_set(): Session ini settings cannot be changed after headers have already been sent in C:\Users\chand\OneDrive\Desktop\Ethical\session_shield.php on line 6

Warning: ini_set(): Session ini settings cannot be changed after headers have already been sent in C:\Users\chand\OneDrive\Desktop\Ethical\session_shield.php on line 7

Warning: ini_set(): Session ini settings cannot be changed after headers have already been sent in C:\Users\chand\OneDrive\Desktop\Ethical\session_shield.php on line 8

[-] Security Flags Applied: HttpOnly=True, Secure=True, SameSite=Strict

[-] Generating unique client fingerprint hash...

[-] Fingerprint: 6ecec4a45afb3ce1f18fc6228c7399fd

[+] SUCCESS: Session strictly bound to client fingerprint to prevent hijacking.

PS C:\Users\chand\OneDrive\Desktop\Ethical>

> OUTLINE

> TIMELINE

mainLaunchpadLive Share

In 12 Col 34 Spaces: 4 UTF-8 CRLF PHP Sign In Go Live Quicka Prettier